iCReaT 임상연구관리시스템 통합 보안 점검 보고서

본 점검은 모의해킹 등 침투시험에 해당하지 않으며, 확인사항은 공개정보에 근거한 잠재적 위험요인 및 추가 점검 필요사항으로 제시함.

▣ 점검 결과 요약: 관련 법령·지침 9종(「개인정보 보호법」 외 8종, 주요 조항 7개)을 근거로 5개 점검 분야(A~E)를 검토한 결과, 적합 0개, 부적합(개선 필요) 2개(A 레거시·B 전송·헤더), 추가 점검 필요 3개(C 인증·계정, D 접근통제, E 민감정보 보호조치)임

□ 점검 개요 및 범위

○ **목적**

- 외부 공개정보를 통한 보안 관리 현황 확인 및 잠재적 위험요인 검토
- 관계 법령·정부 보안지침과 연계한 개선 권고사항 도출

○ **점검 수행 범위**

- 공개 로그인·소개 페이지의 HTML·구성·공개 안내문 확인(일반 방문과 동일한 단일 조회 요청)
- 노출된 기술 스택·버전 단서, 응답 헤더·쿠키, 계정·인증 안내, 전송 방식 관찰

○ **제외사항**

- SQL 인젝션·XSS 등 공격 구문 입력, 인증 우회, 파라미터·디렉터리 퍼징, 계정 열거 및 타 이용자 정보 접근 등 능동적 취약점 탐지·침투 행위

  * SQL 인젝션: 입력값에 데이터베이스 명령문을 삽입하여 정보 조회·변조 또는 인증 우회 등을 유도하는 공격

  * XSS(크로스사이트 스크립팅): 웹페이지에 악성 스크립트를 삽입하여 이용자의 브라우저에서 실행되도록 하는 공격

  * 파라미터 퍼징: 웹 요청의 입력항목에 다양한 값이나 비정상 값을 반복 입력하여 오류 및 취약점을 탐색하는 기법

  * 디렉터리 퍼징: 다양한 경로명을 반복 요청하여 공개되지 않은 폴더·파일·관리자 페이지 등을 탐색하는 기법

- 로그인 이후 인증이 필요한 영역 및 내부 시스템 점검

□ 점검 한계 및 결과 활용

○ **한계**

- 소유 기관(질병관리청)의 서면 승인 없는 능동 점검은 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 위반 소지가 있어 수행하지 않음

- 따라서 실제 취약점의 존재를 확정하지 않으며, 서버 설정·소스코드·인증 영역을 직접 확인하지 못한 추정을 포함함

- 확정 진단은 발주처 승인 하에 KISA 지정 정보보호 전문서비스 기업 등 전문기관의 정식 취약점 분석·평가 및 모의해킹으로 수행해야 함

구분	내용
대상	iCReaT 임상연구관리시스템 로그인 포털 (https://icreat2.nih.go.kr/icreat2/invoke/CM000000/login/v2?langtp=K)
운영기관	질병관리청 국립보건연구원
운영 환경	G-Cloud(공공 클라우드)
점검 일자	2026-11-05
점검 유형	외부 비침투(Non-intrusive) 관찰 — 일반 방문자가 접근할 때 확인되는 공개정보만 대상

○ **결과 활용 및 후속 조치**

- 점검 결과는 보안 개선과제 발굴 및 정식 보안진단 범위 설정을 위한 기초자료로 활용

- 취약점 존재 여부 및 영향도는 소유·운영기관의 사전 승인하에 전문기관의 취약점 분석·평가 및 필요시 모의해킹을 통해 확인

- 정식 진단 시 대상 시스템, 수행 방법, 허용 행위 및 정보보호 조치 등 세부 수행 범위를 사전에 명확히 설정

□ 시스템 개요

○ **iCReaT은 질병관리청 국립보건연구원이 운영하는 웹기반 임상연구관리시스템으로, 과제· 연구대상자· eCRF·자료추출·보고서·모니터링 등 임상연구 전반을 관리함.**

▣ 보안 관점의 함의: 대상자 약 92만 명 규모의 건강정보(민감정보)를 처리하는 공공 개인정보처리시스템으로, 「개인정보 보호법」상 민감정보 및 공공시스템운영기관 관련 강화된 안전조치가 적용됨. 데이터 민감도와 규모가 커 침해 시 영향이 매우 큰 자산임.

항목	내용
운영기관	질병관리청 국립보건연구원
주요 처리데이터	연구과제 정보, 연구대상자 개인정보, eCRF 입력 데이터 등 건강정보(민감정보)
공개된 규모(2026)	과제 721 · 기관 717 · 연구자 9,386 · 대상자 922,230명
사용자	과제 수행 연구자(PI, CRC, CRA, Data Manager)
권한 체계	일반 과제 담당자(소속 과제만 조회·다운로드), 최고 관리자(전체 과제 통합 조회·일괄 다운로드)
버전 구성	Ver.2(표준) · Lite(관찰연구용) · Ver.1 BackUp(아카이브)
준수 표방	미국 21 CFR Part 11(전자기록·전자서명) · Audit trail(변경추적)
인증 방식	ID·비밀번호 + e-Sign(전자서명), 3개월 주기 비밀번호 변경, 로그인 5회 실패 시 계정 잠금

3. 점검 방법론 및 근거 가이드라인

공개 페이지를 조회하여 관찰 가능한 범위에서 기술 구성·버전 단서·응답 헤더·인증 안내·전송 방식을 확인하고, 각 발견사항을 아래 법령·국가 보안 가이드라인에 매핑함. 근거는 법령·고시(R1~R4)와 국가 지침·국내 기술 가이드(R5~R9)로 구분함.

약칭	근거 가이드라인	발행	적용 영역
R1	「개인정보 보호법」	개인정보 보호위원회	제23조(민감정보), 제29조(안전조치의무)
R2	「개인정보 보호법 시행령」	개인정보 보호위원회	제30조(안전성 확보 조치)·공공시스템운영기관 특례
R3	「개인정보의 안전성 확보조치 기준」(고시 제2023-6호, 2023.9.22)	개인정보 보호위원회	제5조(접근 권한 관리), 제6조(접근통제), 제7조(암호화), 제8조(접속기록 보관·점검), 공공시스템운영기관 안전조치
R4	「행정기관 및 공공기관 정보시스템 구축·운영 지침」	행정안전부 고시	개발보안 의무·SW 보안약점 진단 근거
R5	「국가·공공기관 클라우드컴퓨팅 보안 가이드라인」(2023)	국가정보원	접근통제, 계정관리, 인증, 암호화, 접속기록
R6	클라우드 서비스 보안인증(CSAP) 평가기준	과학기술 정보통신부·KISA	접근통제, 계정·인증, 암호화, 로깅
R7	주요정보통신기반시설 기술적 취약점 분석·평가 상세가이드	KISA	웹 애플리케이션·전송구간·서버 점검항목
R8	전자정부 SW 개발·운영자를 위한 소프트웨어 개발보안 가이드(2021)	행정안전부·KISA	구현단계 보안약점 49개(시큐어코딩)
R9	공공 웹사이트 플러그인(ActiveX) 제거 정책·로드맵	행정안전부	레거시 플러그인 제거

• R4의 고시 번호·조항, R5의 명칭·발행연도, R6의 최신 기준 및 국정원 검토 시 준용 여부는 제출 전 원문 대조가 필요함

• 연구대상자 건강·임상정보는 민감정보에 해당하므로 R3 제8조의 강화된 접속기록 보관기간(2년 이상)을 적용함

3-1. 참고: 클라우드 보안인증(CSAP) 개념 및 iCReaT 적용 범위

CSAP(Cloud Security Assurance Program, 클라우드 보안인증제)는 국가·공공기관이 클라우드 서비스를 안전하게 이용할 수 있도록, 해당 서비스가 정부에서 정한 정보보호 기준을 충족하는지 평가하고 인증하는 제도임. 즉, "이 클라우드 서비스를 정부기관에서 사용해도 될 만큼 보안이 갖춰져 있는가"를 검증하는 제도로, 한국인터넷진흥원(KISA)이 운영함(R6).

가. 적용 예시 — 질병관리청이 iCReaT를 민간 클라우드에 구축하는 경우를 가정함

구분	설명
클라우드 제공기업	KT Cloud, NAVER Cloud 등
이용기관	질병관리청, 국립보건연구원
저장·처리 데이터	임상연구정보, 연구대상자 정보 등
CSAP 역할	클라우드 서비스의 보안관리 체계와 기술적 보호조치 검증
추가 확인사항	개인정보보호, 민감정보 처리, 기관 보안정책 충족 여부

• 클라우드 기업이 CSAP 인증을 받았다는 것은 인증받은 서비스 범위에 대해 일정한 보안 기준을 충족했다는 의미임

• 다만 CSAP 인증만으로 임상정보나 유전체 데이터를 제한 없이 저장·처리할 수 있다는 뜻은 아님

나. 주요 평가 영역

평가 영역	확인 내용
접근통제	허가된 사용자만 시스템에 접근하는지
데이터 보호	개인정보 암호화와 데이터 보호조치가 적절한지
네트워크 보안	외부 침입을 차단할 수 있는지
취약점 관리	서버와 소프트웨어의 보안 취약점을 점검하는지
침해사고 대응	해킹이나 장애 발생 시 대응체계가 있는지

• 인증 과정에는 서면·현장평가, 취약점 점검, 보완조치 확인 등이 포함됨

다. 공공기관의 CSAP 필요 여부

• 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제20조에 따라 행정기관 등은 보안인증을 받은 클라우드 서비스를 우선적으로 고려해야 함

• 다만 미인증 서비스 이용에 관한 별도 보안협의 절차도 있으므로, 모든 경우에 무조건 의무라고 단정할 수는 없음

• 제20조의 현행 조문은 제출 전 국가법령정보센터 원문으로 대조가 필요함

라. 본 점검과의 관계

▣ 핵심: CSAP는 클라우드 서비스 자체에 대한 인증임. CSAP 인증을 받은 클라우드에 iCReaT를 구축하더라도, iCReaT 시스템의 개인정보보호 및 보안 적합성은 별도로 검토해야 함. 본 보고서 4장의 발견사항(레거시 버전, 라이브러리, 보안 헤더, 인증·계정, 접근통제, 민감정보 보호조치)은 모두 클라우드 인증과 별개로 iCReaT 애플리케이션과 운영 주체가 이행해야 하는 영역임.

• iCReaT는 현재 G-Cloud(공공 클라우드)에서 운영되고 있음. CSAP는 주로 민간 클라우드 서비스를 이용하거나 전환할 때 검토되는 제도이므로, 현 운영 환경에 대한 적용 여부는 소관 부서 확인이 필요함

4. 주요 발견사항

발견사항은 공개정보로 확인된 것 [확인], 노출 단서로 추정되는 것 [추정], 외부에서 확정 불가하여 점검이 필요한 것 [점검 필요]으로 구분함.

A. 레거시 버전·구성요소 노출

A-1. 단종 예정 Ver.1(ActiveX 기반) 백업 로그인 상시 접근 가능 — [확인]

• 관찰근거: 메인 화면에 'Ver.1 BackUp' 로그인 링크가 상시 노출·접근 가능함. 사이트 안내문은 Ver.1이 Internet Explorer 기반 ActiveX가 필요한 시스템이며 2024년 종료 예정이라고 명시함

• 추정위험: ActiveX·IE 기반 레거시는 보안 패치가 중단된 비표준 기술로 악성코드 유포에 악용된 이력이 있음. 종료 예정 버전이 2026년에도 접근 가능하면 유지보수되지 않는 공격면이 잔존함

• 관련: R9 플러그인 제거 정책, R7 취약점 분석·평가(불필요 서비스 비활성화)

A-2. 지원 종료 프론트엔드 라이브러리 사용 — [확인]

• 관찰근거: AngularJS 1.2.9, jQuery 1.11.2, jQuery UI 1.11.2 사용 확인. 공개 페이지에 미치환 템플릿 바인딩 구문({{noti.NTCSUBJECT}}, {{pagingObj.TOT_CNT ...}} 등)이 노출됨

• 추정위험: AngularJS는 2021년 12월 31일 공식 지원이 종료되어 보안 패치가 제공되지 않으며, 사용 버전에는 공개된 XSS 취약점이 다수 존재함. 미치환 바인딩 노출은 클라이언트 템플릿 처리·주입 관점의 점검 필요성을 시사함. 실제 영향은 해당 기능 사용 여부에 따라 달라짐

• 관련: R8 SW 개발보안 가이드(보안기능·코드품질), R4 SW 보안약점 진단, R7 취약점 분석·평가(오래된 SW 버전)

B. 전송구간·보안 헤더·쿠키 설정

B-1. 브라우저 보안 헤더 미확인 — [확인]

• 관찰근거: 로그인 페이지 응답에서 Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy 헤더가 확인되지 않음. 다만 G-Cloud 앞단 장비(웹방화벽·부하분산기)에서 일부 경로에만 적용될 수 있음

• 추정위험: 미적용 시 다운그레이드, 클릭재킹, XSS를 통한 쿠키 탈취 등에 노출됨

• 관련: R3 제7조(전송 시 암호화·안전한 접속), R7 취약점 분석·평가

B-2. 전송구간 및 세션 쿠키 설정 — [점검 필요]

• 관찰근거(양호): HTTPS로 응답하며 비암호화(HTTP) 혼합 리소스가 없음. Server 헤더에 웹서버 제품·버전이 노출되지 않음. 스크립트 접근 가능 쿠키는 성능 모니터링용 1종이며 세션 쿠키는 스크립트에 노출되지 않음

• 관찰근거(개선 필요): 일부 공지 안내문이 http://icreat.nih.go.kr(평문 스킴)으로 시스템을 안내함

• 외부 확정 불가 항목: TLS 버전·암호스위트 수준, HTTP→HTTPS 강제 전환, 세션 쿠키의 Secure·SameSite 속성

• 추정위험: 미적용 시 중간자 공격·다운그레이드 등에 노출되며, 민감정보 전송·인증 세션에서 영향이 큼

• 관련: R3 제7조, R7 취약점 분석·평가(데이터 평문전송)

C. 인증·계정 관리 — [점검 필요]

• 관찰근거(확인): 로그인 5회 실패 시 계정 잠금 정책 운영(공지 확인) → 긍정적 통제. 비밀번호는 3개월 주기 변경. 비밀번호 찾기는 ID·성명·이메일 입력 시 임시비밀번호를 생성해 SMS로 발송함

• 점검 필요 위험:

◦ 계정 열거: 아이디·비밀번호 찾기·회원정보 찾기 응답이 계정 존재 여부를 구분해 노출하는지 외부 확정 불가

◦ 임시비밀번호 흐름: 복잡도·일회성·만료·최초 로그인 시 강제 변경 적용 여부, SMS 발송 남용 가능성

◦ 다중 인증(MFA): 최고 관리자 계정이 비밀번호 단일 요소로 보호되면 단일 실패 지점이 됨

◦ 세션 관리: 로그인 시 세션 재발급, 유휴 시간 자동 종료, 로그아웃 시 서버측 세션 폐기 여부

◦ 계정·권한 관리: 공유 계정, 퇴직·전보자 권한 미말소, 최고 관리자 권한 과다 부여 여부. 3개월 주기 변경만으로는 계정 탈취를 막기 어려움

• 관련: R3 제5조(접근 권한 관리·인증 실패 시 접근 제한)·제6조(안전한 인증수단·자동 차단), R5 계정관리·인증, R6 계정·인증, R8 SW 개발보안(취약한 복구·인증)

D. 애플리케이션 구조·접근통제 — [점검 필요]

D-1. 서버측 권한 검증 및 대량 반출 통제

• 관찰근거: URL이 /icreat2/invoke/CM000000/ 형태의 명령(invoke) 디스패치 구조로 보이며, 권한 체계상 일반 과제 담당자와 전체 과제를 일괄 다운로드할 수 있는 최고 관리자가 구분됨

• 점검 필요 위험(본 보고서는 능동 테스트를 하지 않으며 구조적 점검 권장만 제시):

◦ 수평적 접근(IDOR): 서버가 요청의 과제·파일 식별자가 요청자 소속 과제의 것인지 검증하지 않으면 식별자 변경만으로 타 과제 자료에 접근 가능함

◦ 수직적 권한 상승: 관리자 메뉴의 화면 숨김은 접근 통제가 아니며, 서버가 요청마다 역할을 확인하지 않으면 일반 계정이 관리자 기능을 직접 호출(강제 브라우징)하거나 권한 필드를 변조할 수 있음

◦ 대량 반출: 순차 식별자, 임시 링크 재사용, 요청 속도·다운로드량 제한 부재 시 단일 계정으로 짧은 시간에 대량 수집이 가능하며 정상 다운로드처럼 보여 탐지가 어려움

• 관련: R3 제5조·제6조(유출 시도 탐지·대응)·제8조(다운로드 사유 확인), R8 SW 개발보안(부적절한 인가), R7 취약점 분석·평가(불충분한 인가·자동화 공격)

D-2. 다중 버전 동시 운영 및 관리 경로 노출

• 관찰근거: Ver.2·Lite·Ver.1 백업이 동시 운영됨

• 점검 필요 위험: 다수 버전 동시 운영은 공격면과 패치 관리 부담을 키움. 운영 환경에 테스트 계정·디버그 기능·API 문서 페이지가 남아 있거나 관리자 접근 경로가 IP 제한·안전한 인증 없이 열려 있으면 인증·권한 통제를 우회하는 경로가 됨

• 관련: R3 제6조(IP 제한·안전한 인증수단), R5 접근통제, R8 SW 개발보안, R7 취약점 분석·평가(불필요 페이지 비활성화)

E. 개인정보·민감정보 보호조치 — [점검 필요]

• 맥락: 약 92만 명 건강정보(민감정보)를 처리하는 공공 개인정보처리시스템. 외부에서 내부 통제 확인은 불가하나 법적 의무 충족 여부를 자체 점검할 영역

• 점검 필요 항목:

◦ 암호화: 고유식별정보·인증정보 저장 암호화, 비밀번호 일방향 암호화, 민감정보 저장 암호화 범위, 백업 데이터 암호화, 암호 키의 데이터 분리 보관 및 키 관리 절차

◦ 접속기록: 기록 항목(계정, 접속일시, 접속지, 처리한 정보주체 정보, 수행 업무), 2년 이상 보관, 월 1회 이상 점검, 다운로드 사유 확인, 위·변조 방지, 이상징후 경보

◦ 관리체계: 접근권한 최소화·직무분리, 공공시스템운영기관 기준 이행, 내부 관리계획, 개인정보 영향평가(해당 시) 수행 여부

• 관련: R1 제23조·제29조, R2 제30조, R3 제7조·제8조, R5 암호화·접속기록, R6 암호화·로깅

5. 발견사항 요약

번호	항목	구분	위험도	관련 가이드라인
A-1	Ver.1(ActiveX) 백업 상시 접근	확인	중	R9, R7
A-2	지원 종료 라이브러리(AngularJS 1.2.9, jQuery·jQuery UI 1.11.2) 사용	확인	중	R8, R4, R7
B-1	브라우저 보안 헤더 미확인	확인	중	R3 제7조, R7
B-2	전송구간·세션 쿠키 설정, 평문 스킴 안내	점검 필요	중~상	R3 제7조, R7
C	인증·계정 관리(계정 열거·임시비번·MFA·세션·권한 관리)	점검 필요	중~상	R3 제5·6조, R5, R6, R8
D-1	서버측 권한 검증(수평·수직) 및 대량 반출 통제	점검 필요	상	R3 제5·6·8조, R8, R7
D-2	다중 버전 동시 운영 및 관리 경로 노출	점검 필요	중	R3 제6조, R5, R8, R7
E	민감정보 보호조치(암호화·접속기록·관리체계)	점검 필요	상	R1, R2, R3 제7·8조, R5, R6

위험도는 외부 관찰에 기반한 상대적 추정이며, 확정 평가는 정식 점검에서 재산정되어야 함.

6. 해결 방안 (법령·정부 가이드라인 기반)

각 발견사항에 대한 조치와 근거임.

A. 레거시 제거·현행화

• 종료 예정 Ver.1(ActiveX) 백업 로그인은 접근 차단 후 제거하고, 데이터 열람이 불가피하면 내부망·전용 통제구간으로 이전. → 근거: R9, R7(불필요 서비스 비활성화)

• 프론트엔드 라이브러리를 지원되는 최신 버전으로 현행화하고, 단종 구성요소 인벤토리를 작성·주기 갱신. 교체 전 사용 기능 기준 영향 분석 수행. 미치환 템플릿 노출은 렌더링·입력검증 점검으로 해소. → 근거: R8(보안기능·코드품질), R4(SW 보안약점 진단)

B. 전송·헤더·쿠키 하드닝

• 전 구간 HTTPS 강제(HTTP→HTTPS 리다이렉트), HSTS 적용, 안내문의 http:// 링크를 https://로 정정

• 보안 헤더 적용: CSP, X-Frame-Options(또는 CSP frame-ancestors), X-Content-Type-Options: nosniff, Referrer-Policy. 앞단 장비 적용 시 전 경로 적용 여부 확인

• 세션 쿠키에 Secure·HttpOnly·SameSite 설정. → 근거: R3 제7조, R7(평문전송)

C. 인증·계정 강화

• 계정 열거 방지: 아이디·비밀번호 찾기 및 로그인 오류 응답을 계정 존재 여부와 무관하게 동일 처리

• 임시비밀번호는 충분한 복잡도·일회성·짧은 만료, 최초 로그인 시 강제 변경, SMS 발송 횟수 제한

• 비밀번호 작성규칙(길이·복잡도·재사용 금지) 강화와 5회 잠금 정책 유지·명문화, 주기적 변경 정책의 실효성 재검토

• 최고 관리자 및 외부 접속 계정에 다중인증(MFA) 적용

• 로그인 시 세션 재발급, 유휴 시간 자동 종료, 로그아웃 시 서버측 세션 폐기

• 계정 대장 정비, 공유 계정 폐지, 퇴직·전보 시 즉시 말소, 권한 부여·변경·말소 이력 3년 이상 보관, 최고 관리자 계정 최소화. → 근거: R3 제5조·제6조, R5, R6, R8(취약한 복구·인증)

D. 접근통제·공격면 축소

• 모든 조회·수정·다운로드 요청에 서버측 객체 소속 검증(수평) 및 역할 검증(수직) 적용, 기본 거부(Deny by Default) 원칙

• 수정 요청은 허용 필드 목록(Allow-list) 방식으로 처리, 역할×기능 권한 매트릭스 문서화

• 다운로드는 요청마다 권한 재검증, 일회성·단기 유효 서명 URL, 추정 불가능한 식별자(UUID 등), 계정별 요청 속도 제한·다운로드량 상한, 대량 다운로드 사전 승인

• 미사용 버전·페이지 비활성화·제거로 공격면을 줄이고 패치 관리를 단일화. 운영 환경의 테스트 계정·디버그 기능·API 문서 페이지 제거, 관리자 접근 경로에 IP 제한·다중인증 적용. → 근거: R3 제5·6·8조, R5 접근통제, R8(부적절한 인가), R7

E. 개인정보 보호조치 이행 확인

• 고유식별정보·인증정보·민감정보 저장 암호화 및 전송구간 암호화, 백업 데이터 암호화, 암호 키 분리 보관 및 생성·이용·보관·배포·파기 절차 수립

• 접속기록 항목 표준화, 운영 서버와 분리 저장·위변조 방지, 2년 이상 보관, 월 1회 이상 점검·다운로드 사유 확인, 이상징후(야간 관리자 접속·비승인 IP·대량 다운로드·권한 변경) 경보

• 접근권한 최소 부여·직무분리, 내부 관리계획 수립·점검, 개인정보 영향평가(해당 시) 수행, 유출 대응 절차 수립. → 근거: R1 제23·29조, R2 제30조, R3 제7·8조

7. 개선 로드맵

시기	조치
단기 (0~3개월)	http:// 링크 정정, HTTPS 강제·HSTS·보안헤더·쿠키 속성 적용, 계정열거 응답 통일, 임시비밀번호 강제변경, Ver.1 백업 접근 차단, 최고 관리자 MFA 적용, 공유 계정 폐지·미사용 계정 말소, 테스트 계정·디버그 기능 제거, 이상징후 경보 설정
중기 (3~6개월)	프론트엔드 라이브러리 현행화, 서버측 권한 검증(수평·수직) 전수 점검 및 다운로드 통제(서명 URL·속도 제한·상한) 적용, 세션 관리 개선, 접속기록 분리 저장·위변조 방지·2년 보관, 저장·백업 암호화 및 키 관리 이행 점검
장기 (6~12개월)	레거시 버전 완전 제거, 정식 취약점 분석·평가 및 모의해킹, 개인정보 영향평가, ISMS-P 관점 상시 점검체계 구축

8. 한계 및 후속 권고

• 본 보고서는 외부 비침투 관찰과 공개 법령·가이드라인에 근거하며, 실제 취약점 존재를 확정하지 않음. 추정 항목은 서버 설정·소스코드·인증 영역의 직접 확인으로 검증되어야 함

• R4·R5·R6은 국정원 보안성 검토 제출 전 기관 정보보안 담당 부서를 통해 최신 원문과 대조·확정해야 함

• 클라우드 인프라의 CSAP 인증 여부는 iCReaT 애플리케이션의 보안 적합성을 대신하지 않으므로(3-1절), 클라우드 인증 확인과 별도로 본 보고서의 발견사항을 이행·점검해야 함

• 후속으로 발주처(질병관리청) 승인 하에 다음을 권고함

1. KISA 지정 정보보호 전문서비스 기업의 정식 기술적 취약점 분석·평가 및 모의해킹

2. 개인정보 영향평가(해당 시) 수행

3. ISMS-P 등 인증·상시 점검 체계와의 연계

• 민감정보 대량 처리 자산인 만큼, 조치 우선순위는 전송·인증·접근통제 등 데이터 보호에 직접 영향을 주는 항목에 둘 것을 권장함

9. 참고 가이드라인 및 출처

• R1 「개인정보 보호법」 — 국가법령정보센터

• R2 「개인정보 보호법 시행령」 제30조(안전성 확보 조치)·공공시스템운영기관 특례 — 국가법령정보센터

• R3 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회 고시 제2023-6호, 시행 2023.9.22)

• R4 「행정기관 및 공공기관 정보시스템 구축·운영 지침」(행정안전부 고시)

• R5 「국가·공공기관 클라우드컴퓨팅 보안 가이드라인」(국가정보원, 2023)

• R6 클라우드 서비스 보안인증(CSAP) 평가 기준(과학기술정보통신부·KISA)

• R7 주요정보통신기반시설 기술적 취약점 분석·평가 상세가이드(KISA)

• R8 전자정부 SW 개발·운영자를 위한 소프트웨어 개발보안 가이드(행정안전부·KISA, 2021)

• R9 공공 웹사이트 플러그인(ActiveX) 제거 정책·로드맵(행정안전부, 2018~2020)

• 참고: 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제20조 — 국가법령정보센터

• 참고: 한국인터넷진흥원(KISA) 클라우드 보안인증(CSAP) 제도 안내

• 참고: AngularJS 공식 지원 종료(2021.12.31) — 버전 지원 상태

• 참고: 국가망 보안체계(N2SF) 보안 가이드라인(국가정보원) — 향후 보안성 검토 기준 변화 대비

점검 대상: iCReaT 임상연구관리시스템 (질병관리청 국립보건연구원)